

Heilmeier Catechism Assessment: Requirements-Driven Semantic Gateway (RDSG v2.0)

Assessed against: "DRAFT Requirements-Driven Semantic Gateway v2.0" (STPA/STAMP Edition), The Value Enablement Group, LLC

Since the document's own "Next Steps" point toward an AI4SE/SE4AI Workshop submission and DARPA BAA contexts, this assessment treats the Heilmeier Catechism as a submission gate, not just a writing exercise. The bottom line: the document is unusually strong on the technical "what/how" questions (2–4) and essentially silent on the programmatic ones a BAA reviewer will look for first (1, 5, 6, 7, 8). That asymmetry — rich mechanism, no plain-language pitch, no risk register, no cost or schedule, no exit criteria — is the main gap to close before submission.

Summary Table

#	Question	Current Support	Why
1	What are you trying to do (no jargon)?	Weak	The idea is simple but every stated version of it is in jargon; no plain-language pitch exists anywhere in the doc
2	How is it done today, and what are the limits?	Partial	Names the "reliability" paradigm and its edge-case failure mode; doesn't name or critique specific competing approaches (guardrail products, RLHF, RAG grounding, NIST AI RMF/EU AI Act tooling,

#	Question	Current Support	Why
			human-review pipelines)
3	What's new, and why will it succeed?	Strong	This is the document's center of gravity — STAMP/STPA applied to AI control, ontology-as-constraint-structure, Simplex Action Gateway, four-failure-mode UCA coverage
4	Who cares, and what difference does it make?	Partial	Loss/stakeholder tables exist; one strong quantified example (Risk Manager persona) is buried and not elevated into an impact argument
5	What are the risks?	Absent	No risk register for the approach itself — only risks the architecture is designed to catch in <i>others'</i> systems
6	How much will it cost?	Absent	No cost model at all — build cost, ongoing governance/curation labor, or runtime compute
7	How long will it take?	Absent	"Next Steps" lists activities with no durations, sequencing logic, or dates

#	Question	Current Support	Why
8	What are the mid-term and final exams?	Partial	Coverage Dashboard (§11.1) and STPA hazard/loss tables (§13) contain the raw material for exam criteria but are framed as ops metrics, not milestones

1. What are you trying to do? (no jargon)

The closest thing to a plain-language statement is in the Executive Summary: the architecture "makes AI-embedded systems controllable" rather than "reliable," and enforces "behavioral constraints" via "SHACL shapes and SWRL rules." That sentence itself contains four terms (controllable vs. reliable as a distinction, SHACL, SWRL, behavioral constraints) that need unpacking for a non-specialist reviewer, and the rest of the document never returns to state the goal more simply — it moves straight into STAMP theory, ontology class hierarchies, and rule tables.

This is worth fixing because the underlying idea translates cleanly into ordinary language: *"AI systems sometimes do the wrong thing, or do the right thing at the wrong time, or never respond at all. Instead of trying to make the AI never make a mistake — which no one knows how to guarantee — this system writes down, in advance, exactly what 'wrong' means for each task, and puts a checkpoint in front of the AI that blocks anything that matches. Irreversible actions (sending money, deleting data, filing something with a regulator) get an extra checkpoint that requires a human's explicit sign-off before they happen."* That is a one-paragraph, jargon-free version of Sections 1, 6, and 6A combined, and it doesn't currently exist anywhere in the draft.

Gap to close: Write a two-to-three sentence plain-language mission statement and put it ahead of the Executive Summary. Assume the reader has never heard of STAMP, SHACL, or ontologies.

2. How is it done today, and what are the limits of current practice?

The Executive Summary's "Why Controllability — Not Reliability" box does real work here: it names the dominant paradigm (measuring AI reliability/accuracy) and gives a specific, well-argued failure mode (a statistically reliable system can still produce catastrophic outputs on edge cases outside its training distribution). Section 1 adds a second critique: requirements

today live in product-management tools, disconnected from the running system, so there's no baseline to trace a failure back to.

What's missing is competitive specificity. A DARPA or workshop reviewer will want to know how this compares to the tools and frameworks people are *actually using* right now for AI governance — for example, output guardrail products (regex/classifier filters bolted onto model output), RLHF/constitutional-AI alignment at training time, RAG-based grounding to reduce hallucination, LLM-as-judge evaluation pipelines, human-in-the-loop review queues, and emerging compliance frameworks like the NIST AI RMF or EU AI Act conformity assessments. None of these are named or contrasted against. Without that, a reviewer can't tell whether RDSG is meant to replace these approaches, sit alongside them, or subsume them — and can't judge the claimed advantage without a named baseline.

Gap to close: Add a short subsection naming 3–5 current approaches to AI governance/safety and stating specifically where each one stops working (e.g., "guardrail classifiers catch content patterns but have no concept of *timing* — they can't detect a correct answer delivered before its prerequisite validation step completes, which is exactly the MisTimed UCA class this architecture targets").

3. What is new in your approach, and why do you think it will be successful?

This is where the document is strongest, and it doesn't need much rework — it needs to be *pointed to* more than rewritten. The novelty claims are specific and well-differentiated:

- Applying Leveson's STAMP/STPA hierarchical control-structure model to AI governance, with an explicit, testable isomorphism table (§1A) mapping STAMP elements to architectural zones.
- Complete UCA coverage across all four STPA failure modes (Missing, Hazardous, MisTimed, Wrong Duration) rather than just "wrong output" detection (§6, §6.3) — this is a genuine expansion beyond typical output-filtering approaches, which almost always only cover the Hazardous/wrong-content case.
- The Simplex Action Gateway at Zone 6 (§6A) as a formal irreversibility checkpoint with a defined handshake protocol (block → route → confirm → execute → log) — this borrows a proven idea from control-systems safety (Simplex architecture) and gives it a concrete audit trail.
- Human-System Process Model Synchronization (§7A) treating stakeholder misunderstanding of the system as a first-class hazard (H-RDSG-HSM-001) rather than an out-of-scope user error — this is a genuinely distinctive move; most AI governance frameworks assume the requirement is correct and only check whether the AI followed it.
- Requirements as ontology individuals with machine-executable enforcement (SHACL shapes, SWRL rules) rather than documents that are forgotten after build.

Where the "why will it succeed" half is thinner: the document asserts these mechanisms will work but doesn't argue feasibility. There's no discussion of prior evidence (e.g., "Simplex architectures have been used in flight control since [X]; we adapt the same block/confirm/execute pattern"), no discussion of computational feasibility at scale (how expensive is SHACL/SWRL evaluation per request, does it introduce latency that conflicts with the NFR performance thresholds the document itself defines in §5.1 and §10.1), and no pilot or prototype results.

Gap to close: Keep the novelty content as-is; add one paragraph of feasibility argument per major mechanism (prior art it builds on, and/or any prototype/simulation evidence), and be explicit that success = the architecture reduces the four named STPA hazards in a measurable way (ties directly into fixing Question 8).

4. Who cares? What difference will it make?

The raw material exists but is scattered rather than argued. Section 13.1's Loss table names six concrete stakeholder groups (regulated entities/end users/oversight bodies; business sponsors/governance teams; legal/compliance/risk; finance/legal/operations/executives; domain stewards/end users; security/privacy/data governance) tied to specific losses (regulatory penalty, loss of trust, unauthorized irreversible action, contextually-wrong-but-formally-correct outputs, data exposure). Section 9's domain table extends this across Risk Management, Data Governance, Security & Access, Compliance & Legal, AI Governance, and Analytics & Reporting — this is a credible breadth-of-relevance argument if drawn out explicitly.

The best concrete evidence of impact is currently buried inside the JTBD illustration in §3.2: the Risk Manager persona example quantifies the benefit directly — reducing time to produce a complete risk assessment from 3 days to 4 hours, and increasing ISO 31000 criteria coverage confidence from 70% to 100%. That is exactly the kind of number a Heilmeier answer needs, but it reads as a worked example of the ontology mechanics rather than as the headline "here's the difference this makes" claim.

Gap to close: Pull the Risk Manager numbers (or a similar quantified scenario) into a dedicated "impact" statement, and convert the stakeholder/loss tables into a short prose argument: who is harmed today by ungoverned AI outputs, and what changes for them if this succeeds (fewer compliance failures, faster risk turnaround, auditable irreversible-action trails, etc.).

5. What are the risks?

This is the largest gap in the document. Everything the architecture discusses under "hazards" (§13) and "misalignment" (§7A) is a risk *the system is designed to detect in the systems it governs* — not a risk to the RDSG program itself. No section asks the reverse questions a reviewer will ask: What if stakeholders can't correctly author UCAs and safe-state definitions for

the four failure modes at the elicitation stage (§4.1) — doesn't the whole enforcement chain inherit whatever gaps exist in that human judgment, and isn't that itself the single largest risk to the entire approach? What is the risk that SHACL/SWRL rule-authoring and ontology curation labor doesn't scale as the number of jobs, personas, and domains grows (§11.1's own review cadence — quarterly UCA review for every Must-priority job — implies a standing labor cost that could become the bottleneck)? What is the risk that comprehensive rule evaluation at Stages 2–4 of the compilation pipeline (§7.1) adds latency that violates the NFR performance thresholds the framework itself is supposed to enforce (§5.1's `sh:NonFunctionalRequirementShape`)? What is the risk of false assurance — that a formally complete-looking control structure gives stakeholders more confidence than is warranted, precisely the failure mode §7A.1's H-RDSG-HSM-001 describes for the *governed* system, but not turned back on the RDSG program itself?

Gap to close: Write an explicit risk register for the RDSG effort, separate from the STPA hazard tables for governed systems. At minimum: elicitation/authoring quality risk, curation-labor scaling risk, runtime performance/latency risk, adoption/organizational-change risk, and the "false formal assurance" risk. For each, state what mitigates it (the document already has candidate mitigations scattered through §7A.3, §11.2, and §14 — they just aren't framed as risk mitigations).

6. How much will it cost?

Absent. There is no cost model anywhere in the 24 pages — not for initial build, not for the standing governance operations described in Section 11 (quarterly UCA reviews, coverage dashboard maintenance, requirements lifecycle management), and not for runtime compute (vector DB indexing per Section 8, SHACL/SWRL evaluation per request, immutable audit logging per Section 6A.2). Given that Section 11.1 describes recurring quarterly review cycles and Section 14 describes onboarding requirements for every new AI capability (defining `FunctionalJobs`, completing UCA elicitation, specifying `SafeStateDefinitions`, configuring reversibility classification), there is clearly an ongoing labor cost baked into the design — it's just never quantified or even acknowledged as a cost line.

Gap to close: Even an order-of-magnitude cost model would help: engineering cost to stand up the ontology/SHACL/SWRL layer for a pilot domain, recurring analyst labor for STPA/UCA review cadence (§11.1), and any infrastructure/compute delta versus a baseline (ungoverned) deployment.

7. How long will it take?

Absent. Section 14's "Next Steps" box lists five activities (STPA analyst review of UCA completeness, domain steward validation of `SafeStateDefinitions`, Simplex Gateway reversibility classification review, integration with the companion Morphism-Grounded Compositional Assurance Architecture, and BAA/workshop submission prep) but attaches no durations, no

dependencies between them, and no target dates. There's also no phased rollout plan — e.g., single domain pilot first, then expansion per the six-domain coverage table in Section 9.

Gap to close: Turn the "Next Steps" list into a schedule: rough duration per step, which steps can run in parallel versus which are gated on prior steps, and a milestone date for when the architecture would be validated against at least one production domain.

8. What are the mid-term and final "exams" to check for success?

Partial, and this is the closest of the missing four to being fixable with material the document already has. Two building blocks exist:

- The Coverage Dashboard (§11.1) already defines measurable completeness metrics: % of active FunctionalJobs with all four UCA types defined, % of Must-priority UCAs with an enforcing TMP or UCA rule, % of Irreversible Zone 6 actions with Simplex Gateway configuration, % of ScenarioRequirements with a populated SafeStateDefinition. These are good *mid-term* exam candidates — they measure whether the control structure has been built out, not yet whether it works.
- The System-Level Hazards and Constraints table (§13.2) defines exactly the failure conditions a *final* exam should test against: does H-RDSG-001 (an unvalidated response reaching a user) ever occur in a pilot deployment; does H-RDSG-002 (an irreversible Zone 6 action executing without a valid human approval token) ever occur; does H-RDSG-005 (human-system misalignment going undetected) occur and go unflagged. A final exam is naturally "run this architecture against a real domain for N months and demonstrate zero occurrences of H-RDSG-001 through H-RDSG-006, with full audit trails for every Irreversible action."

Neither of these is currently framed as an exam — they're framed as ongoing operational dashboards and a living hazard registry, which is the right way to run the system once deployed, but not the same as a bounded, dated go/no-go checkpoint a program reviewer is looking for.

Gap to close: Explicitly designate a mid-term checkpoint (e.g., "by month X, Coverage Dashboard shows 100% UCA-type completeness for the pilot domain's Must-priority jobs") and a final checkpoint (e.g., "by month Y, a live pilot in [domain] shows zero unmitigated occurrences of H-RDSG-001–006 over a defined observation window, validated by an independent STPA review"). This converts existing metrics into the catechism's required exam structure with almost no new content — just reframing.

Bottom line

Sections 3 and, to a lesser extent, 4 are already close to submission-ready — the STAMP/STPA grounding, the four-failure-mode UCA taxonomy, and the Simplex irreversibility gateway are genuinely distinctive and well-specified. Questions 1, 5, 6, and 7 are not weak so much as

unaddressed: there's no plain-language pitch, no risk register turned inward on the RDSG program itself, no cost model, and no schedule. Question 8 is the cheapest fix — the coverage metrics and hazard tables already exist and mostly need reframing as dated go/no-go checkpoints rather than new content. Given the document's own stated trajectory toward a DARPA BAA and workshop submission, closing 1/5/6/7 specifically is what stands between this draft and a Heilmeier-complete narrative.